

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-28 · Source SHA: `61ed8c3`

Summary

Metric	Count
Total dependencies scanned	24
Total CVEs found	79
CRITICAL CVE dependencies	2
HIGH CVE dependencies	4
MEDIUM CVE dependencies	3
Outdated dependencies	8
License violations	1
Supply-chain alerts	2

Known-vulnerable Dependencies (pre-remediation)

Dependency	Version	Top CVE	CVSS	Severity	Fix version	Status
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.1	✅ Fixed in this PR
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.17.1	✅ Fixed in this PR
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	8.0.33	✅ Fixed in this PR
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.17.1	✅ Fixed in this PR
com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	7.5	HIGH	3.25.5	✅ Pinned in this PR
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.0-jre	⚠️ MAJOR_REVIEW — issue opened
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.17.1	✅ Pinned in this PR
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.14.0	✅ Fixed in this PR
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.14.0	✅ Fixed in this PR

Critical CVE Details

CVE	Dependency	CVSS	Severity	Description
CVE-2021-44228	log4j-core 2.14.1	10.0	CRITICAL	Log4Shell — JNDI injection RCE via log message
CVE-2021-45046	log4j-core 2.14.1	9.0	CRITICAL	Log4j2 JNDI lookup bypass (CVE-2021-44228 incomplete fix)

CVE-2019-14379	jackson-databind 2.9.8	9.8	CRITICAL	Deserialization gadget RCE via SubTypeValidator
CVE-2020-9546	jackson-databind 2.9.8	9.8	CRITICAL	Deserialization RCE via shaded Jodd-db gadget
CVE-2023-22102	mysql-connector-java 8.0.30	8.3	HIGH	MITM downgrade attack on MySQL connectors
CVE-2024-7254	protobuf-java 3.19.4	7.5	HIGH	Stack overflow via recursive protobuf parsing
CVE-2022-3171	protobuf-java 3.19.4	7.5	HIGH	DoS via crafted protobuf parsing
CVE-2023-2976	guava 24.1.1-jre	7.1	HIGH	Insecure temp directory creation allows privilege escalation
CVE-2018-1000873	jackson-annotations 2.9.0	6.5	MEDIUM	Polymorphic deserialization DoS
CVE-2021-29425	commons-io 2.4	4.8	MEDIUM	Partial path traversal in FileNameUtils
CVE-2024-47554	commons-io 2.4	4.3	MEDIUM	Uncontrolled resource consumption via XmlStreamReader
CVE-2025-48924	commons-lang3 3.4	5.3	MEDIUM	ReDoS in StringUtils.containsAny

Supply-Chain Alerts

CRITICAL — Typosquatted dependency removed.

`com.fastxml.jackson.core:jackson-databind:2.9.8` impersonated the legitimate `com.fasterxml.jackson.core` (groupId missing "er"). This coordinate does not exist on Maven Central and is a potential supply-chain attack vector. **Removed in this PR.**

HIGH — Untrusted plain-HTTP repository removed.

`http://insecure-mirror.example.net/maven2` was declared as a Maven repository over plain HTTP (MITM artifact-injection risk). **Removed in this PR.**